

CYBER SECURITY Steering Committee

(CSSC 29-04-2025)

XYZ | XYZ Only

Agenda

SN	AGENDA	PRESENTER(S)
1	Introduction & clarification on the pre-read (5 minutes)	Chair
2	Update on previous action items (5 minutes)	P-A
3	Cybersecurity Performance Metrics (5 minutes)	P-A
4	Summary of incidents (10 minutes)	P-A
5	Cybersecurity Emerging Threat Overview (15 minutes)	P-A
6	Journey through maturity (10 minutes)	P-C/P-B/P-A
7	Data Protection and Cyber Risk Grid (10 minutes)	P-B/P-A
8	Open Discussion and Q&A (10 minutes)	

XYZ | XYZ Only

Private & Confidential ©

02.

Update on previous action items

Previous Action Items

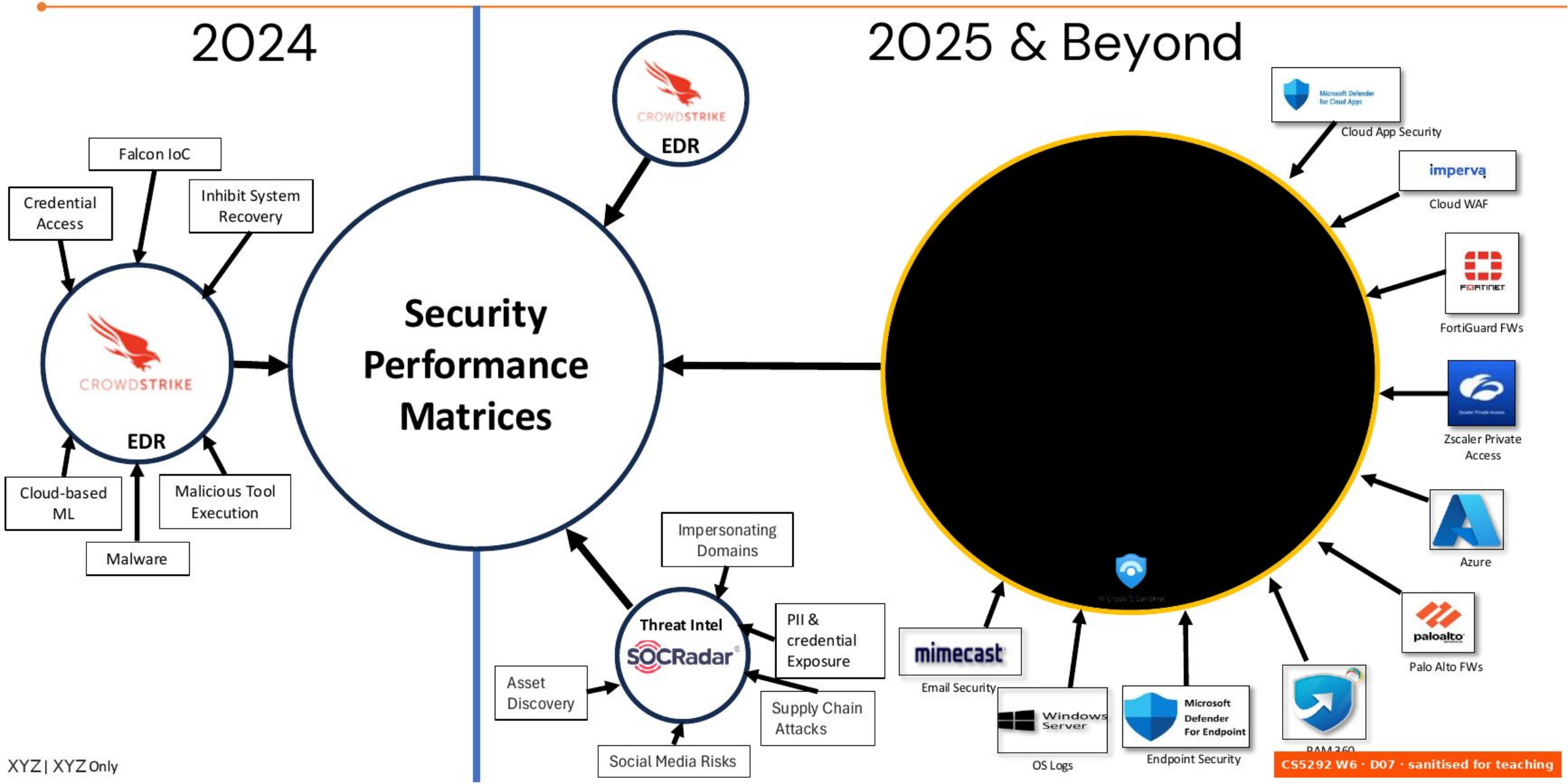
Entered on	Action discussed	Responsible	Due	Action taken	Status
15th October 2024	Develop AI policy for XYZ	P-B	17th Jan 2025	Policy drafted. Awaiting socializing sessions from the consultant	Completed



03.

Cybersecurity Performance Metrics

Cybersecurity KPIs – Transforming to all data points



Cybersecurity KPIs Q1 2025

SOC Detections Q1 2025	Priority	Q4 (2024)	Q1 (2025)	SLA	
Mean Time to Respond (by MSSP)	P1	-	0.3 Hrs	15 mins	
	P2	-		30 mins	
	P3	-		60 mins	
	P4	-		120 mins	
Mean Time to Respond (by XYZ SOC)	P1	-	13.3 Hrs	15 mins	
	P2	-		30 mins	
	P3	-		45 mins	
	P4	-		60 mins	
Mean Time to Resolve (MTTR)	P1	-	26.7 Hrs	24 Hrs	⬇
	P2	-		48 Hrs	
	P3	-		5 Days	
	P4	134hrs 40mins		14 Days	

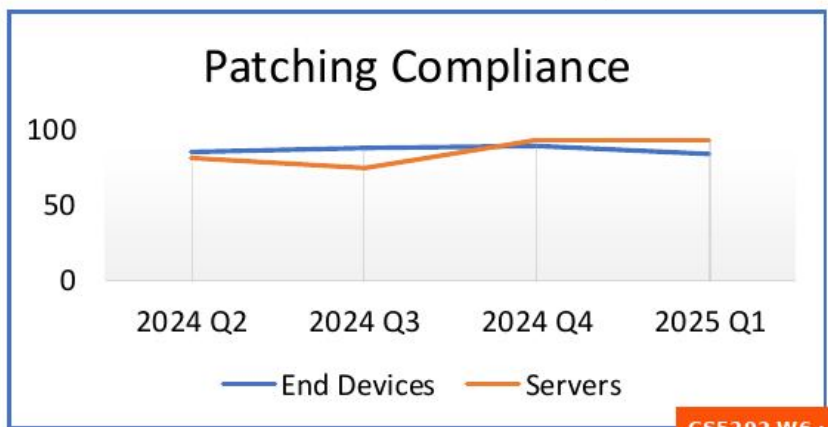
* From 2025, Sources of Incidents: SIEM, EDR & TI

* The industry standard for **Mean Time to Respond** in cybersecurity benchmark is around 24 hour

* Average Organizations typically have a Mean **Time to Resolve** ranging from 24 to 72 hours.

Patching Compliance:

Windows Device Compliance	N	N-1	End of Support
End Device	⬆ 12.99%	83.83%	4.6%
Servers		93.00%	11.0%



*End of support is considered as compliant

CS5292 W6 · D07 · sanitised for teaching

Security KPI – Tracking and Insights

- Over 75% of incidents originate from the TI platform, with credential exposures of both employees and vendors being the primary contributors to these incidents.
- Due to automations and finetuning conducted in Q1 this year, escalated EDR alert volume reduced by approximately 51%
- There is a 16% increase in total SIEM alert escalations in Q1 2025 compared to Q4 2024, primarily attributed to the implementation of the new SIEM
- 35% of escalated alerts generated from the SIEM platform in Q1 2025 were associated with user and entity behavior analytics (UEBA) detections.

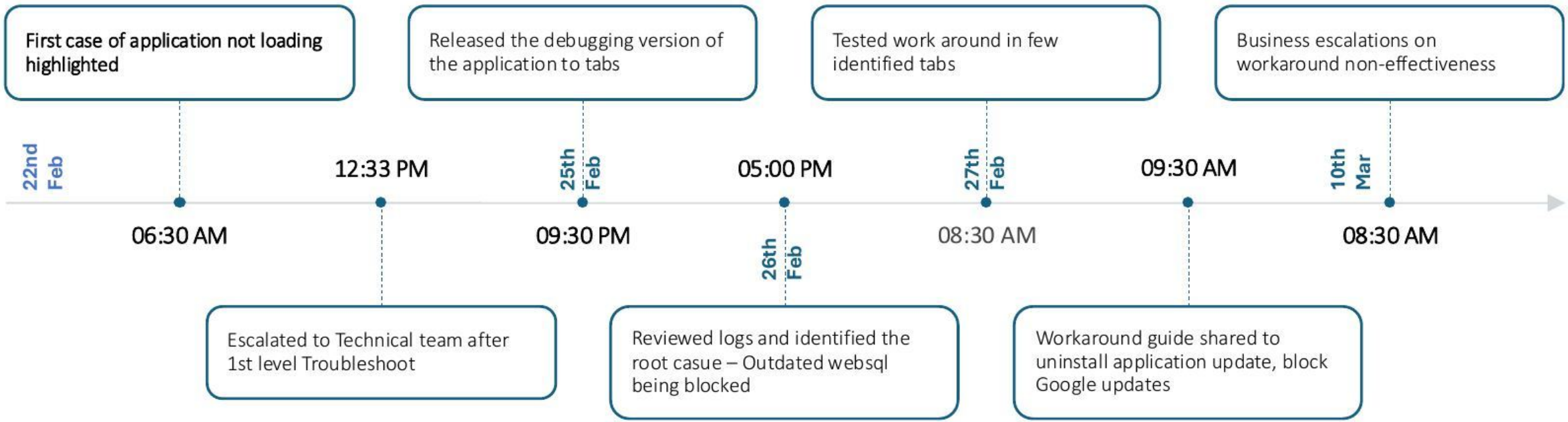
Security Universe
real-time tracker demo

04.

Summary of Incidents

Shopfloor Incident

Cyber Risk Grid ID/s
02



Key Take aways:

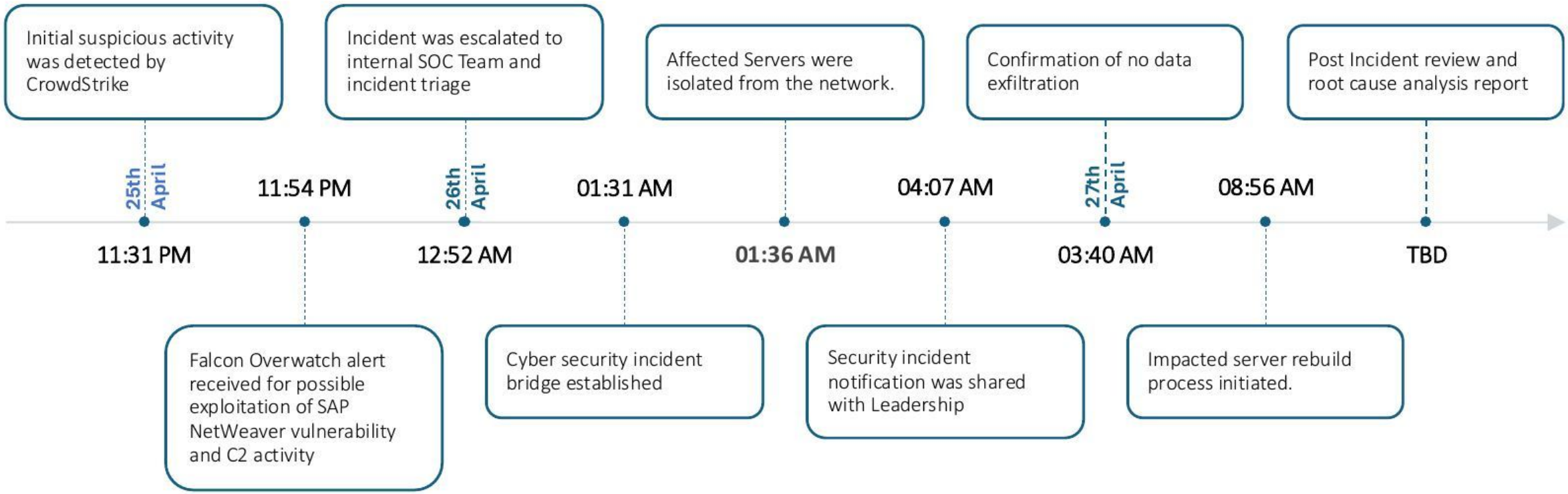
- Shopfloor modernization delayed due to Project-X,as the MES was part of the project.
- Currently as the functions are impacted due to no google updates, decided to modernize (ETA 6-9 weeks)

Impact:

- 150 tabs were impacted (27/02/2025).
- Reduced impact continuing throughout. (10/03/2025)

SAP NetWeaver Vulnerability Incident (as at 28/05/2025)

Cyber Risk Grid ID/s
06



Key Take aways:

- Threat actor exploited a critical zero-day vulnerability on an internet facing system.
- Delay in security monitoring allowed extended threat actor activities.
- Currently as the functions are impacted due to Impacted server rebuild process (ETA 3 days / 30th of April 2025).

Impact:

- 3 Servers impacted

05.

Cybersecurity Emerging Threat Overview

Cybersecurity Emerging Threat Overview



Increase in Region-Specific APT Activity:

One bank suffered a major cybersecurity breach involving the exfiltration of over 1.9TB of data including more than one million files. Compromised information includes customer PII such as NICs/Passports, financial records and credit reports. The breach indicates a targeted APT campaign abusing remote access, highlighting increased threat actor interest in this geographic region.



Supply Chain Attacks:

OneGroup experienced a cybersecurity incident affecting their customer portal which handles RFID,UPC and QR code data. While the root cause and the impact remains undisclosed yet, potential exposure of customer product data is suspected. The incident led to six days of production capacity for XYZ, highlighting critical concerns around third party security posture and the growing importance of supply chain cyber security resilience.



Application and API Vulnerability:

To Safeguard the organization application and API security posture, Checkmarx security solution is employed to identify and mitigate application and API related security issues. complementing this, a Qualys vulnerability management tool ensure continues monitoring and remediation of identified risks. Together these solutions provide a comprehensive defense against potential exploits and vulnerabilities against applications and APIs.



Increase in Threat Actor Activities around [country]:

Due to recent bank, incident, lof of threat actors and access broker activities are witnessed around [coun Timer is set for a BFSI company for data leakage, e-commerce/gifting platform are on the breach lists. Increase in activities are observed across the attack surface.

06.

Journey Through Maturity

Pre-read & Present

Sub-A [redacted] Project & Security State Assessments

Risk Assessment: Customer-N is carrying out an information risk assessment program from 22APR to 23MAY for Customer-N factory partners. Following areas are in scope.



- Network Architecture and Security
- Server/Endpoint Architecture and Security
- IT Infrastructure Management
- Data Lifecycle Management
- Business Continuity & Disaster Recovery Program
- Incident Management
- Threat & vulnerability Management
- Walkthrough Physical Locations & Assets
- Identity and Access Management
- Governance, risk and compliance policies

Red teaming assessment:

- Vendor-E has been selected as vendor for red team assessment.
- Focused on both external and internal breach scenarios to assess complete defence layers.
- 16 weeks of estimated engagement, started by April 10th and expected to have final report and executive briefing in mid of July.



Defence layers activated:

- Mimecast Email Security – Enabled to all 1350 Sub-A users
- Qualys VA – Enabled for all 27 servers
- Zscaler ZIA and ZPA – Enabled for 981 and 680 users respectively (out of 1350 and 792)
- CrowdStrike EDR – Enabled for 1306 endpoints

Sub-A **Domain Migration & Network Refinement Status:**

- Share correct SA users according to XYZ standards – 21st March
- Initiate the Exchange Online/OneDrive & . SharePoint/Teams Migration – 5th May
- Final Cutover – 30th July
- Completion of Network Refinement for SA Site-1, Site-2 & Site-3 – 30th November

Cyber Security Projects

Pre-read

Cloud Security Posture Management (CSPM)

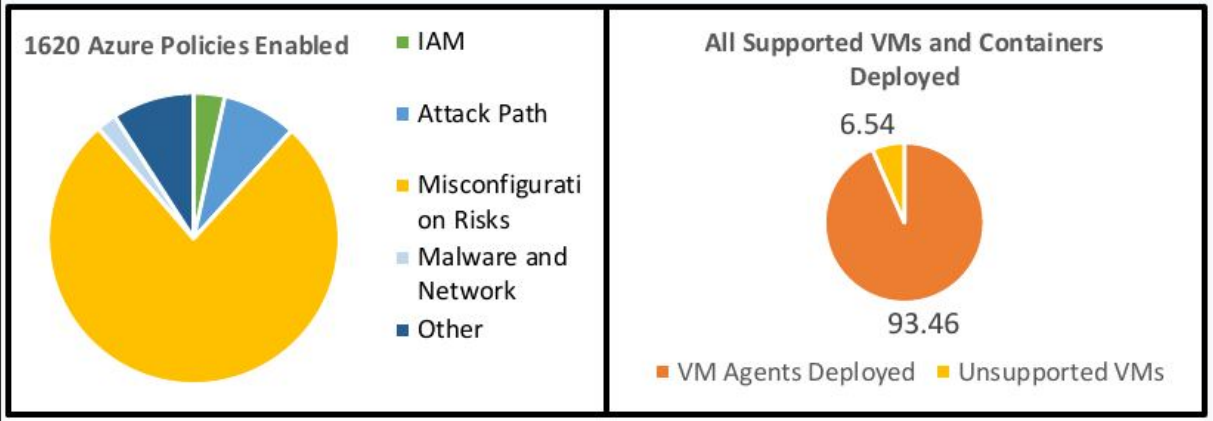
Prisma CSPM

Visibility, Compliance, and Governance
Establish guardrails and maintain compliance across public clouds

Threat Detection
Detect and respond to threats across clouds with network anomaly detection and UEBA

Data Security
Malware scanning across public cloud storage

What We Have Done So Far



Compliance Checks Configured

- CIS Microsoft Azure Foundations Benchmark
- ISO/IEC 27001:2022 Information security management systems (ISMS)
- ISO/IEC 27002:2022 Information security controls

Project Status	Completed

Security Information and Event Managment (SIEM)

Real-time Monitoring and Alerting
Continuously Monitor security events and alert for immediate threat detection & response

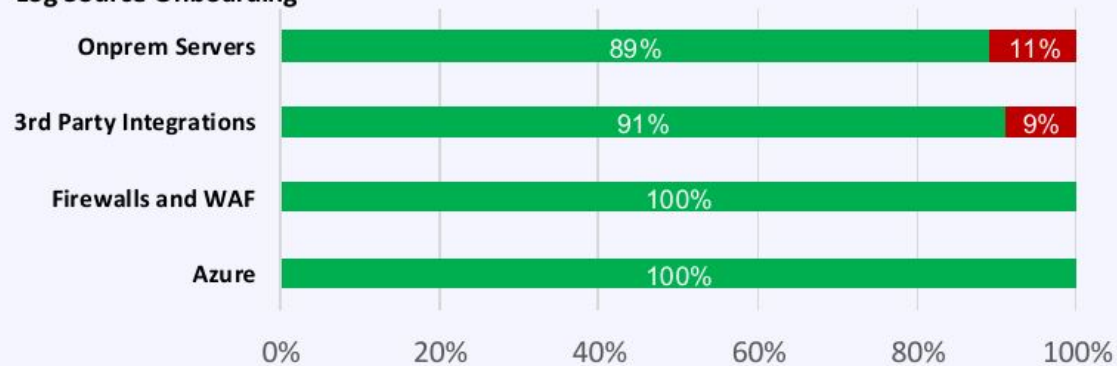
User and Entity Behavior Analytics
Detect anomalies by analyzing user and entity behavior

Security Orchestration Automation and Response
Automate and coordinate responses to security threats.

Microsoft Sentinel

What We Have Done So Far

Log Source Onboarding



UEBA Integration	Completed
Custom Dashboard	Completed
Detection Rules	149
Monitoring & Escalation	Started

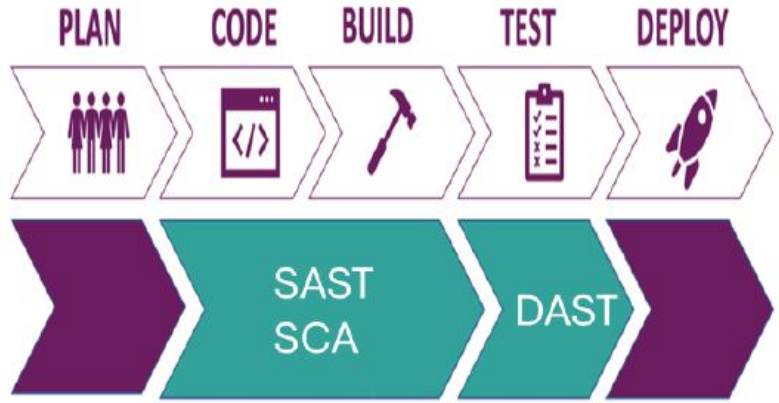
Lighthouse Integration	Completed
Automation Rules	02 Active
Log Verification	In Progress
Log Finetuning	In Progress

Project Status	In Progress

Pre-read

Cyber Security Projects

Objective: Integrating application security at development phase and eliminate vulnerability in source-code and 3rd party libraries or modules and ensure secure build through CI/CD pipeline.





SAST and SCA

- Detects vulnerabilities early in the development phase and provides detailed code-level insights for fixes.
- Identifies vulnerabilities in open-source dependencies and provides visibility into third-party components.
- Helps manage license compliance risks and enforce secure coding practices

What we have done so far

Product knowledge	• Checkmarx completed product walk-through scheduled and conducted for SOC, DE and cloud team.
Integration	• Completed Checkmarx Integration with Azure code repo and CI/CD pipeline
Coverage	• On-boarded 100% (40) of projects in Azure repo integrated using webhook in CI/CD pipeline including critical projects.
Process	• AppSec process drafted with identified roles and responsibilities between SOC and DE – DE to finalize the final draft for their areas
Configuration	• Baselining configuration for source-code scanning tested and completed
Operation	• Parallel to AppSec process establishment prioritized projects based on criticality and completed scanning all 40 projects for vulnerabilities, reviewing and triaging started

Project Status: Completed

Pre-read

Cyber Security Projects

Objective: Discovering, prioritizing and remediating vulnerabilities in Servers and network devices and web applications to reduce risk and protect assets across SBUs, DC, DR and Azure IaaS fleet



Qualys

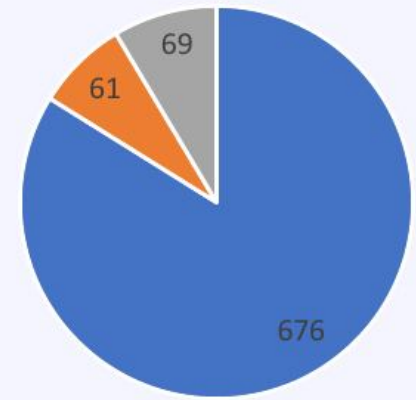
Continuous Vulnerability Assessment – Identifies security weaknesses across environments, with agent-based comprehensive scanning.

Attack Surface Management – Identifies exposed services and misconfigurations that could lead to breaches.

Integrated Threat Intelligence – Correlates vulnerabilities with exploits and malware to assess risk.

Compliance & Reporting – Helps meet regulatory requirements (PCI DSS, HIPAA, ISO 27001, etc.)

What we have done so far



Asset tagging and grouping based on criticality	Completed
Agent configuration for scanning	Completed
Scanning appliance deployment	Completed
Custom dashboards - 5 steps remediation	Completed
Scanning, prioritization and remediation	Started

Project Status: In-progress

Device compliance

Crowdstrike (CS) Coverage
99.83%

CS Coverage	Count
Covered	15455
Not Covered	21

- Intune deployment issue
- Not installed - 1

ZScaler (ZS) Coverage
99.30%

ZS Coverage	Count
Covered	15368
Not Covered	108

- Subic is still not under XYZ domain, so Zscaler cannot be used in those devices. - 102
- Excluded – 3
- Intune deployment Issue - 3

Outdated OS

OS	Count
Microsoft Windows 8	4
Microsoft Windows 8.1	3
Microsoft Windows 7	11
Microsoft Windows XP	1
Linux	27

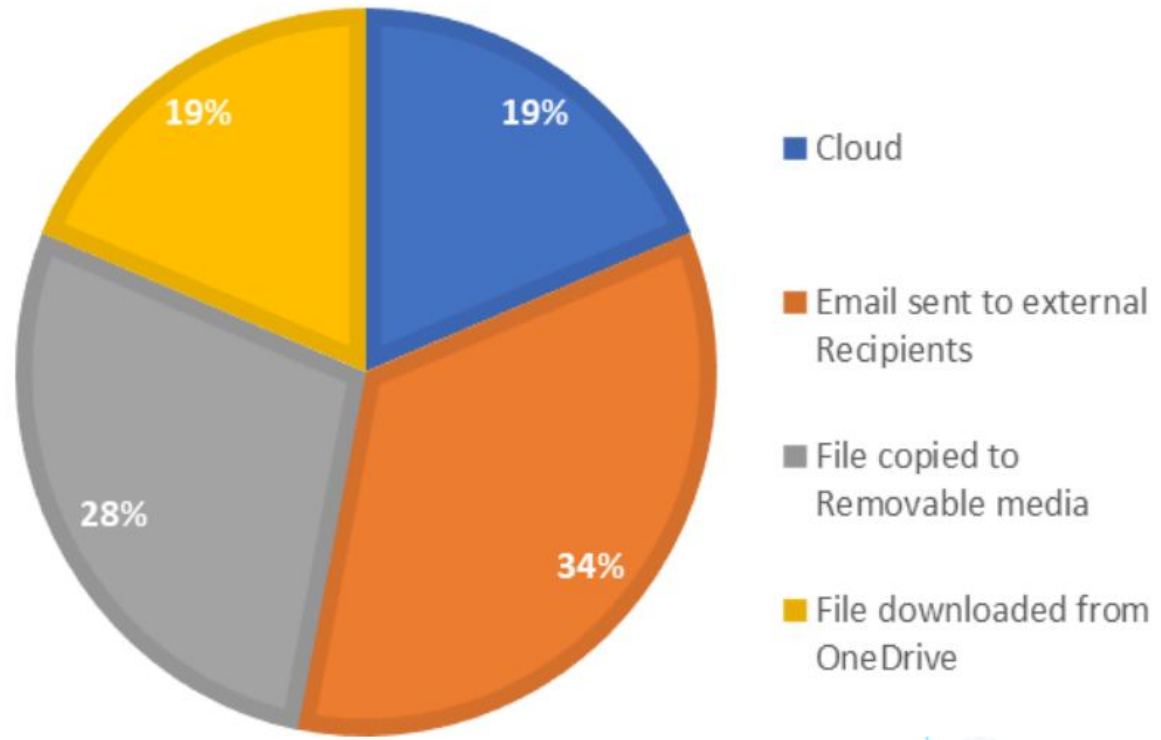
07.

Data Protection and Cyber Risk Grid

DLP Statistics

Critical Alerts Investigated in Q1 2025

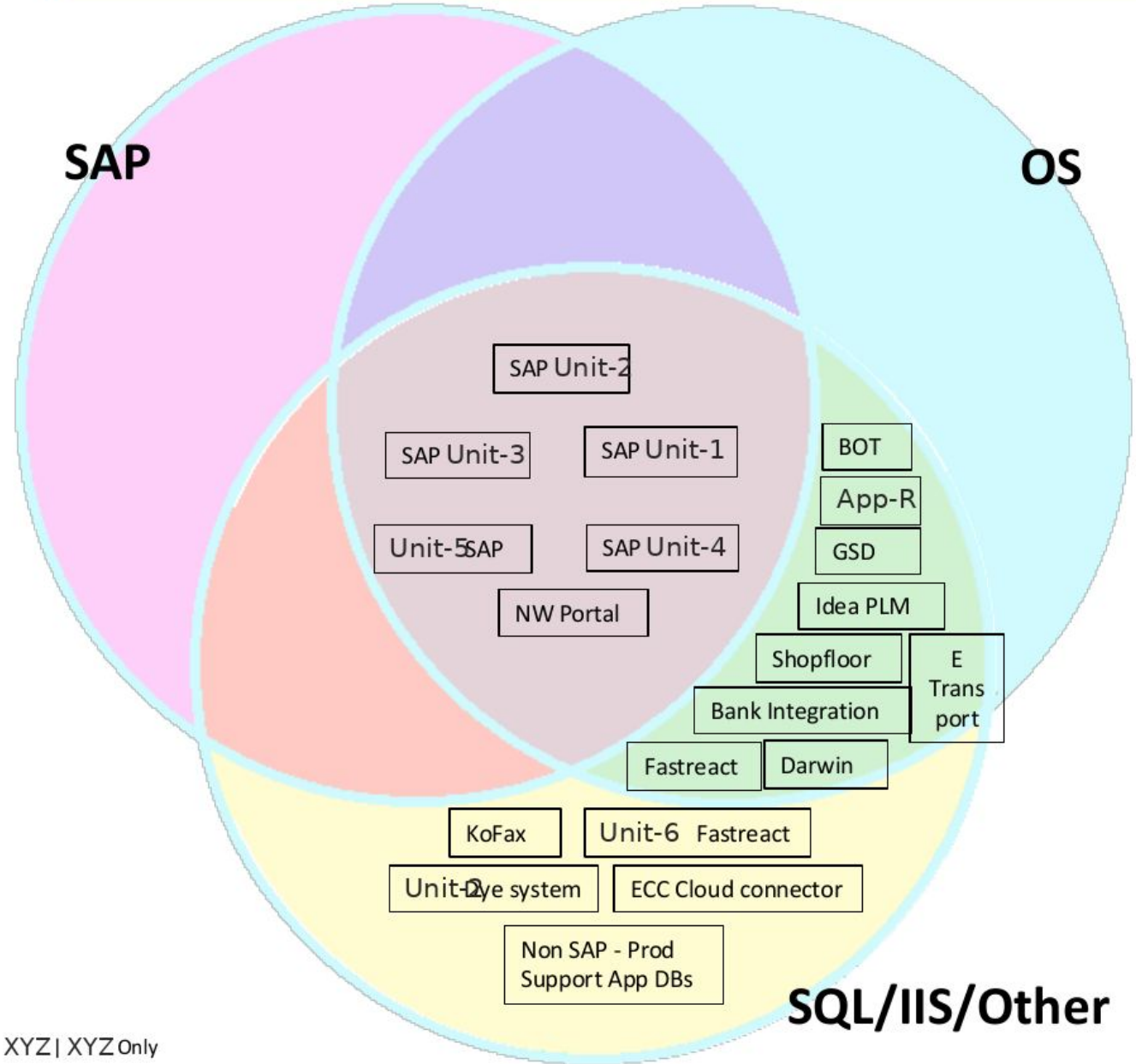
Status	#
Closed	31
Open*	1
Total	32



*Open incidents are pending user or line manager response



Vulnerabilities in Core Systems



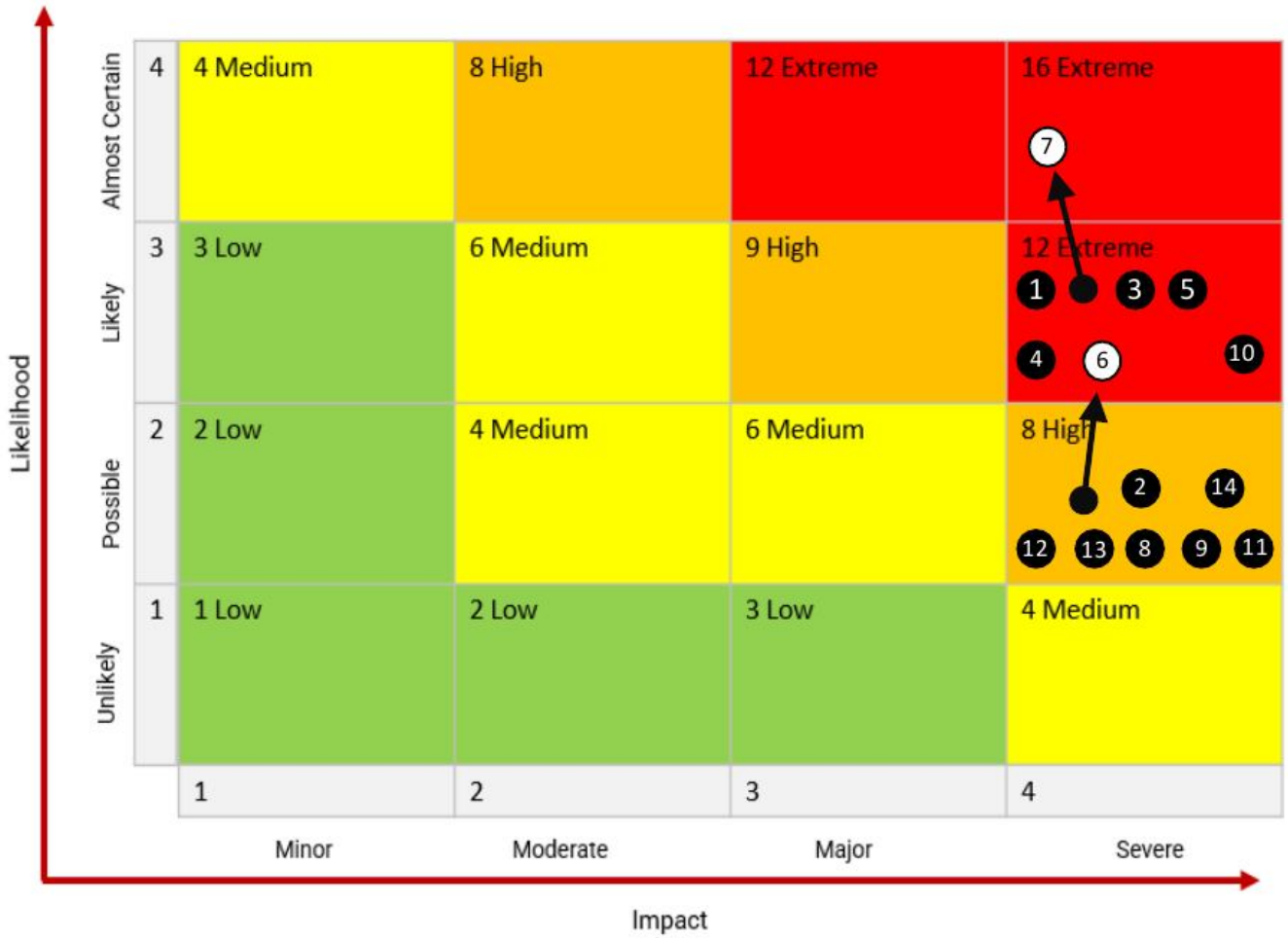
Our Red Zones: Critical and High Vulnerabilities Snapshot

The core systems affected are critical to our operations, remediating these high and critical vulnerabilities would significantly minimize attacks and operational disruption. Many of these vulnerabilities need coordinated changes across applications, and vendor components, which require dedicated time, resources and licensing or upgrades.

Critical Applications	Critical	High
SAP Unit-3	32	50
SAP Unit-2	72	163
SAP Unit-4	18	23
SAP Unit-1	16	24
Unit-5 SAP	4	13
NW Portal	39	164
Shopfloor	44	106
Idea PLM	8	34
GSD	12	71
Bank Intergration	26	56
App-R	18	35
Non SAP - Production Supportive App DBs	6	19

Critical Applications	Critical	High
Fastreact	40	249
BOT	62	320
Darwin	11	62
ECC Cloud connector	5	54
KoFax	11	128
E Transport	58	246
Unit-2 ye system	2	19

Cyber Risk Grid (Q1, 2025)



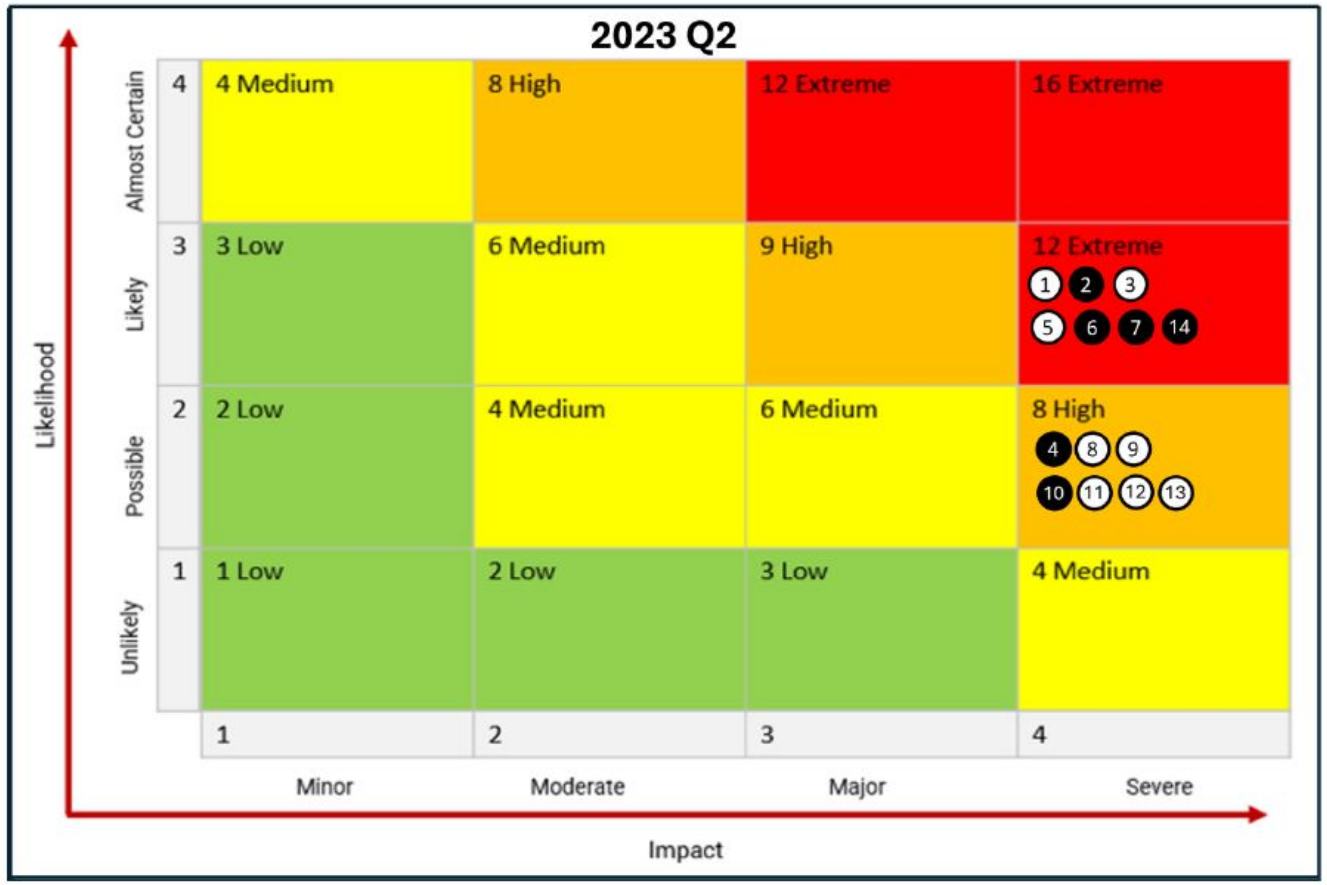
Up to USD 10,000	USD 10,000 – 500k	USD 500k – 1.5mn	> USD 1.5 Mn

Please refer to the appendix for the KRIs

#	Headline Risk
1	Risk of an attack by a cyber criminal due to lack of employee awareness.
2	Risk of an attack by a cyber criminal as result of using unpatched /vulnerable/End of Life/End of Support software's and/or applications and/or EOL Hardware devices
3	Risk of attack by a cyber-criminal, exploiting vulnerabilities in unsupported systems devices leading to system downtime - Embedded Devices
4	Risk of Cyber Security incident as a result of SBU/JVs not adhering to the XYZ TS standards - XYZ-Sub- / XYZSub-B USA / Sub-C
5	Risk of a cyber security Incident as a result of a vulnerability/vulnerabilities in the core business system (SAP) - For Unit-1/Matrix /Unit-2
6	Risk of a cyber security Incident as a result of a vulnerability/vulnerabilities in the core business system
7	Risk of a cyber security incident as a result of an attack by a cyber criminal as a result of a supply chain attack
8	Risk of a cyber security Incident as a result of an unmanaged IT Asset within XYZ Infrastructure. Unmanaged Server/Laptop /API Connection
9	Risk of a cyber security incident as a result of Shadow IT
10	Risk of a Cyber security incident as a result of a device/system misconfiguration i.e. Misconfiguration in a AD Server or Perimeter firewall and/or System.
11	Risk of a Cyber Security incident as a result of inadequate IT Asset Management Policy
12	Risk of a Cyber Security Incident as a result of a malware infection
13	Risk of Cyber Security Incident as a result of activities of State Sponsored and/or organized crime cyber criminals /cyber terrorists targeting XYZ Holdings
14	Risk of a cyber security incident /intrusion as a result of lack of adherence to standard operating procedures within XYZ Technology Services

Risk Movement and Accountability

Pre-read & Present



Up to USD 10,000	USD 10,000 – 500k	USD 500k – 1.5mn	> USD 1.5 Mn

Please refer to the appendix for the KRIs

Way forward:

L3 – Cyber Security Goal: "No financial claims from customers or regulatory authorities, No disruptions to business operations due to in-effective security controls, Security incidents occur but are contained with minimal impact and within SLA"

Requires below adjustments in risk management to align risk appetite:

Risk management (Identify, asses, treat) to be formally established to ensure methodical and continuous reduction of risk.

Risk management and reduction goals to be assigned for multiple leaders.

Risk management to be empowered with Governance manager establishing accountability operationally to drive reducing risks, enforcing controls sustainably.

07.

Open Discussion and Q&A

APPENDIX 1



Pre-read

Cyber Risk Grid – Key Risk Indicators (Q3, 2024)

#	Headline Risk	KRI
1.	Risk of an attack by a cyber criminal due to lack of employee awareness.	Include phishing simulation tracker with victim out of total users Reduction Plan 24% clicks rate - Almost certain <10% click rate - Likely <5% click rate - Possible <3% click rate - Unlikely
2.	Risk of an attack by a cyber criminal as result of using unpatched /vulnerable/End of Life/End of Support software's and/or applications and/or EOL Hardware devices	Reduction Plan - (end devices 88%, servers 75%) - Almost Certain (end devices 86%, servers 82%) - Likely (end devices 95%, servers 90%) - Possible (end devices 100%, servers 100%) - Unlikely
3.	Risk of attack by a cyber-criminal, exploiting vulnerabilities in unsupported systems devices leading to system downtime - Embedded Devices	Develop list of devices other than Workstations and Servers -> list and vendor patch release status
4.	Risk of Cyber Security incident as a result of SBU/JVs not adhering to the XYZ TS standards - XYZ-Sub- / XYZ Sub-B USA / Sub-C	List of non-governed XYZ entities-> compliance level for security (Endpoint security, Email security, Internet security, Application security, Network Security) List of critical vendors->compliance level Self Assessment to be provided Self assesment score average < 50% - Almost certain <75% - Likely <85% - Possible <95% - Unlikely
5.	Risk of a cyber security Incident as a result of a vulnerability/vulnerabilities in the core business system (SAP) - For Unit-1/Matrix /Unit-2	List of Tier 1 applications, VA conducted for Tier 1 application <70% - Almost Certain <80% - Likely <90% - Possible 100% - Unlikely

Cyber Risk Grid – Key Risk Indicators (Q3, 2024)

#	Headline Risk	KRI
6.	Risk of a cyber security Incident as a result of a vulnerability/vulnerabilities in the core business system	List of Tier 1 applications, VA conducted for Tier 1 application <70% - Almost Certain <80% - Likely <90% - Possible 100% - Unlikely
7.	Risk of a cyber security incident as a result of an attack by a cyber criminal as a result of a supply chain attack	List of critical vendors->compliance level Self Assessment to be provided Self assesment score average < 50% - Almost certain <75% - Likely <85% - Possible <95% - Unlikely
8.	Risk of a cyber security Incident as a result of an unmanaged IT Asset within XYZ Infrastructure. Unmanaged Server/Laptop /API Connection	A-% of devices deployed through intune B-% of local admin accounts detected C-% of browserware detected in CS IT hygiene Almost certain (A <80%, B<10%, C>300) Likely (A<90%, B<5%, C<300) Possible (A<95%, B<1%, C<100) Unlikely (A=100%, B=0, C<50)
9.	Risk of a cyber security incident as a result of Shadow IT	
10.	Risk of a Cyber security incident as a result of a device/system misconfiguration i.e. Misconfiguration in a AD Server or Perimeter firewall and/or System.	List of domain servers, firewall baseline configuration < 80% compliance - Almost certain <85% compliance - Likely <95% compliance - Possible 100% compliance - Unlikely
11.	Risk of a Cyber Security incident as a result of inadequate IT Asset Management Policy	A-% of devices enrolled through auto pilot B- % of devices enrolled through Intune C- Device lost case wipe average time Almost certain (A <80%, B<20%, C<5 days) Likely (A<90%, B<5%, C<3 days) Possible (A<95%, B<5%, C<2 days) Unlikely (A=100%, B=0,

Cyber Risk Grid – Key Risk Indicators (Q3, 2024)

#	Headline Risk	KRI
12.	Risk of a Cyber Security Incident as a result of a malware infection	A-Non-Deployment of CrowdStrike for XYZ assets B-Coverage of mailboxes through Mimecast A< 50 endpoints, B<95% - Almost certain A<30 endpoints, B<98% - Likely A<20 endpoints - Possible 100% compliant on CS, B<99.5 - Unlikely
13.	Risk of Cyber Security Incident as a result of activities of State Sponsored and/or nation state cyber criminals /cyber terrorists targeting XYZ Holdings	Number of threat intel incidents detected (numbers to be defined after setting up SOC radar process)
14.	Risk of a cyber security incident /intrusion as a result of lack of adherence to standard operating procedures within XYZ Technology Services.	

End of Pre-read | THANK YOU